Degen Token Contracts

Security Review

Cantina Managed review by:
Om Parikh, Security Researcher
Arno, Associate Security Researcher

February 21, 2026

Contents

1 Introduction **2**
1.1 About Cantina . . . 2
1.2 Disclaimer . . . 2
1.3 Risk assessment . . . 2
1.3.1 Severity Classification . . . 2

2 Security Review Summary **3**
2.1 Scope . . . 3

3 Findings **4**
3.1 Informational . . . 4
3.1.1 Permanent pause risk if ownership is renounced . . . 4
3.1.2 Owner-controlled minting . . . 4
3.1.3 Standard OpenZeppelin-based ERC20 implementation . . . 4

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	**Impact: High**	**Impact: Medium**	**Impact: Low**
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

From Feb 16th to Feb 18th the Cantina team conducted a review of degen-token-contracts on commit hash 5454ef38. The team identified a total of **3** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	3	0	0
Total	**3**	**0**	**0**

2.1 Scope

The security review had the following components in scope for degen-token-contracts on commit hash 5454ef38:

```
contracts/DegenToken.sol
```

Which is deployed at address 0x4ed4E862860beD51a9570b96d89aF5E1B0Efefed in the Base network.

3 Findings

3.1 Informational

3.1.1 Permanent pause risk if ownership is renounced

Severity: Informational

Context: DegenToken.sol#L127

Description: The contract's pause and unpause functions are restricted to the owner. If the owner pauses the token and then renounces ownership (or otherwise sets the owner to the zero address), there will be no authorized account left that can call `unpause()`. In that state, transfers (and typically minting/burning under the pausable ERC20 design) can remain blocked forever, effectively bricking the token from an operational perspective. This is unlikely to occur intentionally, but it is a real "*foot-gun*" during administrative or decentralization steps.

Recommendation: Prevent ownership renouncement while the token is paused.

3.1.2 Owner-controlled minting

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description: The token supply is not permanently fixed. The owner can mint additional tokens using the `mint` function once minting is enabled. Minting is rate-limited (by a time delay between mints) and capped to a percentage of the current total supply per mint, but it remains an active administrative capability. Exchanges should treat this asset as a mintable token and assess the associated centralization and supply-inflation risk.

Minting Restrictions: Minting cannot begin until the predefined start time. The on-chain minting start timestamp is **`1830297600` (January 1, 2028, 00:00:00 UTC)**, so no new tokens can be created before this date.

After each mint, the contract enforces a lock period of approximately **365 days**, which means minting can happen **at most once per year**.

Each mint event is limited to **1% of the current total supply**, so the maximum mint amount scales with the existing supply.

There is no permanent disable or sunset mechanism. As long as the limits are respected, the owner may continue minting indefinitely.

Example: If the circulating supply is **1,000,000,000 tokens**, the maximum that can be minted in one event is **10,000,000 tokens (1%)**. After minting, the next mint will only be possible after roughly **one year**. This process can repeat indefinitely.

Recommendation: Place the owner behind a multisig and define clear operational procedures for any mint events.

3.1.3 Standard OpenZeppelin-based ERC20 implementation

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description: The token is built on widely used, battle-tested OpenZeppelin contracts (ERC20, burnable, pausable, permit, and votes). These libraries are commonly used across major protocols and exchanges, and they reduce the risk of custom implementation bugs because core token behavior (transfers, allowances, EIP-2612 permits, and voting checkpoints) is handled by established, audited code rather than bespoke logic. The contract's custom logic is limited in scope (mainly minting and owner-controlled pause), which further reduces attack surface compared to heavily customized tokens.

Recommendation: No change required.